资料

nginx 鉴权 / 权限 排查清单

一、500 错误（Basic 认证相关）

顺序	检查	命令	判断
1	看错误日志	`tail -20 /var/log/nginx/error.log`	`Permission denied` → 权限问题
2	nginx 运行用户	`grep -E '^user' /etc/nginx/nginx.conf`	Debian=www-data / RHEL=nginx
3	htpasswd 权限	`ls -l /etc/nginx/*.htpasswd`	期望 `root:nginx 640`
4	路径逐级权限	`namei -l /etc/nginx/xxx.htpasswd`	目录也要可进入
5	修复后自检	`curl -o /dev/null -w '%{http_code}'`	匿名 401 / 认证 200

二、401 / 403

- 401 = 要认证但没给 / 给错
- 403 = 认证通过但无权（路径、`deny/allow`、`auth_basic off` 写错位置）
- 检查 `auth_basic_user_file` 路径是否存在、是否在正确 location

三、htpasswd 生成

```
openssl passwd -apr1 'YourPass'
htpasswd -B -b /etc/nginx/example.htpasswd demo 'YourPass'
printf 'demo:%s\n' "$(openssl passwd -apr1 'YourPass')" >
        /etc/nginx/example.htpasswd
```

四、加固清单

- [ ] 全站 HTTPS，HTTP 301
- [ ] HSTS
- [ ] 默认拒绝鉴权 + 例外白名单
- [ ] htpasswd `root:<worker> 640`
- [ ] 备份配置不要以 `.conf` 结尾
- [ ] 变更后 401/200 自检

> 仅用于自有或已授权资产。